

9 elementos que distinguen un **playbook real** de un documento de intenciones

Cómo auditar un procedimiento de respuesta a incidentes en menos de 5 minutos – aplicado a phishing, ransomware y DDoS.

NIST SP 800-61

MITRE ATT&CK

SANS

ISO/IEC 27035

PHISHING

Vector de entrada más frecuente en incidentes graves. Bifurcación crítica según interacción del usuario.

RANSOMWARE

Mayor impacto operativo inmediato. Contención automatizada en menos de 10 segundos.

DDoS

Interrumpe disponibilidad sin comprometer datos. La clasificación del tipo es obligatoria.

9

ELEMENTOS
CLAVE

6

FASES NIST
CUBIERTAS

3

ESCENARIOS
AUDITADOS

5min

PARA AUDITAR
UN PLAYBOOK

La base: alcance, activación y mando

01 Nombre, versión y alcance

Define qué cubre el playbook — y qué NO cubre.

Sin esto: el analista aplica el procedimiento equivocado a un incidente fuera de su scope.

02 Triggers de activación

Eventos concretos y medibles que disparan el procedimiento.

Sin esto: la activación llega tarde o depende del criterio de cada turno.

03 Roles y responsabilidades

Quién hace qué en cada fase, definido por rol — no por persona.

Sin esto: ambigüedad de mando, retrasos y acciones contradictorias.

El cuerpo: proceso, precisión y trazabilidad

04 Las 6 fases NIST completas

Preparación, Detección, Contención, Erradicación, Recuperación, Lecciones Aprendidas.

Sin esto: sin Erradicación el atacante vuelve; sin Lecciones, el equipo no mejora.

05 Acciones técnicas concretas

Herramienta, query y umbral exactos — no "analizar los logs".

Sin esto: cada ambigüedad cuesta minutos críticos bajo presión.

06 Mapeo a MITRE ATT&CK

Conecta cada paso de detección con la técnica real del adversario.

Sin esto: imposible auditar qué técnicas cubre realmente tu stack.

El cierre: escalado, comunicación y medición

07 Criterios de escalado con tiempos

Destinatario concreto y ventana temporal explícita en cada transición.

Sin esto: incidentes mayores gestionados con urgencia de incidente menor.

08 Pautas de comunicación

NOC, CISO, Legal y clientes necesitan información distinta, en tono distinto.

Sin esto: mensajes inconsistentes o declaraciones externas prematuras.

09 Métricas — MTTD / MTTC / MTTR

Tiempo de detección, contención y recuperación.

Sin esto: no hay forma objetiva de saber si el equipo mejoró.

Tecnología, proceso y personas — ninguno funciona solo

TECNOLOGÍA

Herramientas correctas,
bien configuradas e
integradas entre sí.

- ✓ Alcance y versión
- ✓ 6 fases NIST completas
- ✓ Escalado con tiempos

PROCESO

Playbooks, escalado,
post-mortem. Sin esto la
tecnología no activa.

- ✓ Triggers de activación
- ✓ Acciones concretas
- ✓ Pautas de comunicación

PERSONAS

Analistas entrenados,
con simulacros
periódicos y cultura de
mejora.

- ✓ Roles y responsables
- ✓ Mapeo MITRE ATT&CK
- ✓ Métricas MTTD/MTTC/MTTR

*"Un incidente bien gestionado no es el que no ocurrió.
Es el que el equipo supo cómo responder."*

→ Guarda este post para tu próxima auditoría de playbook